

Cloud Security Frameworks

A Comparison to Evaluate Cloud Control Standards

TAARIKA HEGDE, Johns Hopkins University, United States

JOSH GANGL, Johns Hopkins University, United States

STANISLAV BABENKO, Johns Hopkins University, United States

JOEL COFFMAN*, Johns Hopkins University, United States

The expansion of cloud computing applications and services has introduced a number of control and audit frameworks designed to provide a standard around data access, cloud security, and digital enablement. While certification frameworks and security standards have become the de facto industry guidance for IT governance, there is a notable absence of a fundamental rating and review system for the frameworks themselves. This research evaluates cloud provider security standards set forth by ISO/IEC 27001 and 27002, FedRAMP, and SOC 2 against a third-party benchmark, the Cloud Controls Matrix (CCM) created by the Cloud Security Alliance (CSA), as well as the CSA’s “Treacherous Twelve” of the top threats to cloud computing security. Recent revisions of ISO/IEC-27001 and 27002 and FedRAMP significantly improve their coverage of CCM controls; SOC 2 provides less coverage overall but remains a viable alternative to the aforementioned certifications.

CCS Concepts: • **Security and privacy** → *Security requirements; Trust frameworks; Software and application security.*

Additional Key Words and Phrases: ISO/IEC 27001 and 27002, FedRAMP, SOC 2, CSA CCM, certification, standard, framework, cloud computing, security, privacy

ACM Reference Format:

Taarika Hegde, Josh Gangl, Stanislav Babenko, and Joel Coffman. 2023. Cloud Security Frameworks: A Comparison to Evaluate Cloud Control Standards. In *2023 IEEE/ACM 16th International Conference on Utility and Cloud Computing (UCC '23), December 4–7, 2023, Taormina (Messina), Italy*. ACM, New York, NY, USA, 6 pages. <https://doi.org/10.1145/3603166.3632553>

1 INTRODUCTION

Cloud security has emerged as a critical issue, ranking as the top concern of 2023 for multiple organizations [12]. Both governmental bodies and the IT industry have dedicated substantial efforts and resources to combat cloud security threats with increased investment in governance strategies [8]. Guiding these cloud security strategies are standards, which are accepted best practices, and frameworks, both generalized and specialized, which aim to provide effective safeguards against cloud security threats.

*Also with United States Air Force Academy, Department of Computer and Cyber Sciences.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

UCC '23, December 4–7, 2023, Taormina (Messina), Italy

© 2023 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM ISBN 979-8-4007-0234-1/23/12...\$15.00

<https://doi.org/10.1145/3603166.3632553>

The proliferation of standards within the cloud security space has highlighted the concern of a “jungle of standards” [6]. Di Giulio et al. [9, 10] compared ISO/IEC 27001:2013, FedRAMP Rev. 4, and the Cloud Computing Compliance Controls Catalog (C5), but an updated analysis of the major cloud security frameworks is not available. The evolving nature of threats and updates to these standards in the interim means the prior analysis is outdated and insufficient in comprehensively addressing the current threat landscape.

In this paper, we analyze the most recent versions of the ISO/IEC 27000 family of standards and FedRAMP. Our research underscores the improvements and remaining gaps pertaining to the 2022 version of ISO/IEC 27001 and 27002 (hereafter ISO/IEC 27001/02:2022) and FedRAMP Rev. 5, which was released in 2023. We also expand upon prior work by including the System and Organization Controls (SOC) 2 framework to highlight differences between more stringent international and government frameworks and a commercial framework, thereby contrasting the comprehensiveness between the public and private sectors. We compare the aforementioned frameworks against a common set of criteria, the CSA CCM, version 4, originally published in January 2021, to quantify the coverage of controls against a third-party checklist. By quantifying the controls within each framework against the most recent CSA CCM, we provide insight into their respective contributions to the security of cloud service providers (CSPs) and ensure the robustness of these cloud security standards against real world implications.

The remainder of this paper is organized as follows. Section 2 provides background information about the frameworks we analyzed. Section 3 details our research method. Section 4 describes the results of our analysis, including changes manifested in recent versions of these frameworks and how they compare against a common baseline. Section 5 reviews our major findings. Section 6 surveys related work. Finally, Section 7 summarizes the key takeaways and future work.

2 BACKGROUND

To guide our analysis, we first differentiate between a standard, framework, and certification. We define a *standard* to be both specific and accepted best practice. A *framework*, however, comprises more general guidelines that provide room for additional tools and practices to be incorporated as needed [3]. Finally, a *certification* is a formal attestation by a third party that serves as proof that the cloud service provider or product meets a set of security and data protection benchmarks. For simplicity, “framework” can refer generically to ISO/IEC 27001/02, FedRAMP, or SOC 2, but when speaking directly about certifications or standards, we refer specifically to ISO/IEC 27001/02 or FedRAMP.

We include SOC 2 as the only non-certifying assessment in our work. Cloud provider services or products that meet the criteria of ISO/IEC 27001/02 or FedRAMP are certified by their respective governing authorities. However, SOC 2 has no certifying body. Therefore, we consider SOC 2 to be only a framework.

We use the CSA CCM as a benchmark, which we define to be a standard, or point of reference, for comparison. The CSA CCM provides a bridge between general information security principles (e.g., ISO/IEC 27001/02) that are applicable across industries and detailed, targeted guidance for security practices specific to CSPs.

2.1 ISO/IEC 27001 and 27002

ISO/IEC 27001, developed by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), is a globally recognized standard for information security management systems and is applicable to all types of organizations. ISO/IEC 27001 is complemented by ISO/IEC 27002, a compilation of information security controls with guidelines for implementation. These standards emphasize risk assessment and management and provide general security guidelines that are not specific to the cloud.

The 2022 versions of both documents have significant updates compared to the 2013 versions. Several clauses have been updated, but the most significant is the requirement that “the organization shall establish, implement, maintain and continuously improve... processes and their interactions.” ISO/IEC 27002:2022 also streamlines the controls, which are organized as follows:

Organizational 37 total, of which 3 are new and 28 were merged
People 8 total, of which none are new and 2 were merged
Physical 14 total, of which 1 is new and 5 were merged
Technological 34 total, of which 7 are new and 21 were merged
 It also addresses adapting to rapidly changing security landscapes.

2.2 FedRAMP

The Federal Risk and Authorization Management Program (FedRAMP) is a U.S. government initiative designed to enhance cloud security and streamline the authorization process for cloud service providers working with federal agencies. FedRAMP provides a framework to assess, authorize, and monitor the security of cloud products and services. The program ensures that federal agencies can leverage secure and reliable cloud solutions while effectively managing risks associated with storing and processing sensitive government data.

In May 2023, FedRAMP approved its latest revision, Revision 5, which introduces significant updates and improvements. FedRAMP authorizes cloud services at one of three levels based on the impact of the loss of confidentiality, integrity, or availability (the “CIA triad”) to an agency’s operations, assets, or individuals:

Low Impact Limited adverse effect

Moderate Impact Serious adverse effect including significant operational damage to assets, financial loss, or individual harm

High Impact Severe or catastrophic adverse effect such as loss of life or financial ruin

FedRAMP does not allow controls to be tailored. For example, if any attribute of the CIA triad qualifies as high impact for a system,

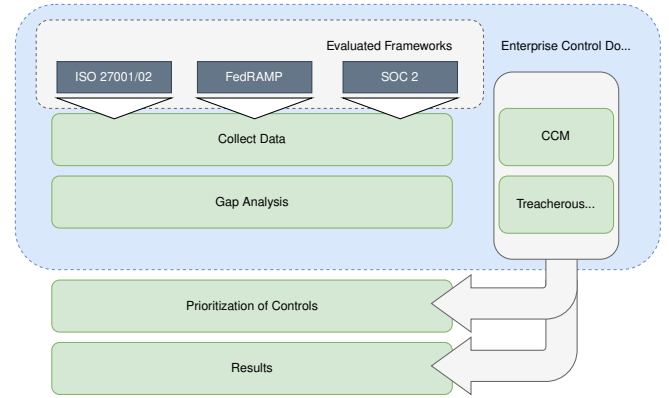


Fig. 1. Security controls are evaluated across 3 frameworks, with a gap analysis guiding the evaluation against the CCM and Treacherous Twelve.

then the system must satisfy the requirements for the high impact level of the other attributes as well. We use the Low Impact Level baseline set of controls in our analysis.

2.3 SOC 2

SOC 2 is developed and maintained by the American Institute of Certified Professional Accountants (AICPA). It is an auditing standard focused on providing assurance of controls related to the Trust Services Criteria (TSC): security, availability, processing integrity, confidentiality, and privacy. It assesses both security and privacy controls of organizations, including that of cloud service providers. The scope of a SOC 2 assessment can vary based on the organization’s services and relevant TSC: out of the five TSC, the security criteria is required and the remaining four criteria are optional depending on the scope of the assessment. Organizations undergoing a SOC 2 assessment must demonstrate the implementation of controls meeting the selected TSC.

SOC 2 is an easier and less expensive framework to implement and maintain than ISO/IEC 27001/02 [14]. We investigate the coverage in controls SOC 2 provides, specifically focusing on the controls related to security.

3 METHODOLOGY

We approached our analysis in two phases. First, we focused on differences between certification versions by collecting control lists for ISO/IEC 27001/02 (2013 and 2022), FedRAMP (Rev. 4 and Rev. 5), and SOC 2. Second, we compared individual controls to a common baseline, the CCM controls. Third, we mapped the controls within each framework to the “Treacherous Twelve” threats to cloud computing security to identify the significance of the control gaps identified. Through this process, we assess the presence or absence of security controls within the aforementioned frameworks and identify any gaps or emphases the frameworks place on relevant security control categories. Our systematic review process is illustrated in Figure 1.

3.1 Comparison of Certification Versions

In this phase, we compared the latest versions of ISO/IEC 27001/02 and FedRAMP with prior versions of each respective certification.

The controls from the latest version of the certification were mapped to the prior version. Any new controls appearing in the latest version that did not appear in the prior version were tallied. We also noted any omissions of controls in the latest versions.

3.2 Comparison of Individual Controls

In this phase, we mapped the individual controls to the controls within the CCM. The overall goal for the mappings was to be as specific as possible, cautioning towards under-mapping versus over-mapping. It is not enough for two controls to be related: it must be obvious that implementing one control implies implementing the other. Our labels follow the guidelines from the Center for Internet Security (CIS) on mapping controls between assessments [11]. The possible labels for the relationship between controls mapped from each of the assessments to the CCM are as follows:

No Gap The defensive mitigation contains the exact security concept as the CCM control.

Partial Gap Either i) the CCM control is partially or mostly related, yet is subsumed within the defensive mitigation because the defensive mitigation in question is more broad of a concept than the CCM control or ii) the CCM control is partially or mostly related to the defensive mitigation in question, but the CCM control is more broad of a concept.

Full Gap The CCM control is not represented in the defensive mitigation, and there is no relationship.

Figure 2 illustrates the evolution of the CCM controls, comparing CCM v3, which was released in 2013, with CCM v4, which was released in 2021. We use CCM v4 for our analysis.

3.3 Treacherous Twelve

The “Treacherous Twelve” was published by CSA to highlight the top threats to cloud computing security [1]. In order to narrow the scope of controls to the most impactful, prior work [9, 10] evaluated the cloud security certifications against the Treacherous Twelve threats. We reproduced the same evaluation by comparing the controls in ISO/IEC 27001/02:2022, FedRAMP Rev. 5, and SOC 2 to the Treacherous Twelve. The individual controls from each framework were mapped to the latest version of the Treacherous Twelve, the “Pandemic Eleven” [2], in order to establish whether critical controls are included across each framework. Since its original publication in 2016, denial of service, shared technology vulnerabilities, and CSP data loss and vulnerabilities have been removed in favor of a need to address issues situated higher in the technology stack that often result from senior management decisions.

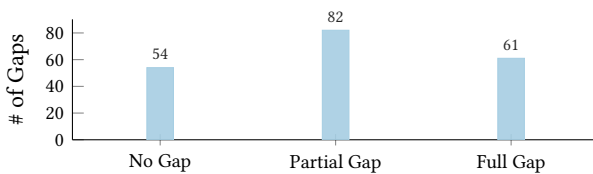


Fig. 2. Gap analysis of CCM v3 against the CCM v4 controls

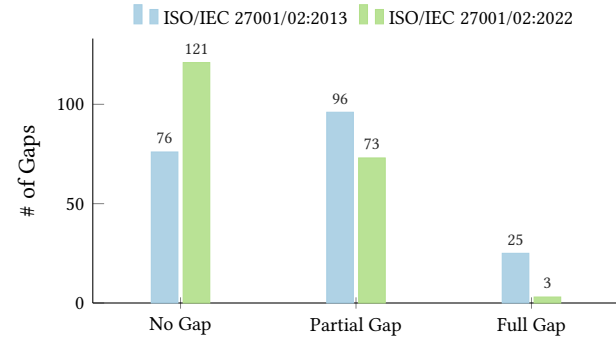


Fig. 3. Gap analysis against ISO/IEC 27001/02:2013 and ISO/IEC 27001/02:2022

4 RESULTS

This section details the results of our analysis. We step through the gap analysis conducted across prior versions of ISO/IEC 27001/02 and FedRAMP to their most recent versions. In addition, the three frameworks are compared against CCM v4.

4.1 ISO/IEC 27001/02:2022

We found that ISO/IEC 27001/02:2022 fully covers 61.5% of the controls included in CCM v4 with 37% of controls having partial gaps and 1.5% with no overlap. For the partial gaps, there were sometimes technical gaps in the ISO/IEC 27001/02 controls, but many of these were attributed to the CCM control specifying a minimum frequency for review or update (e.g., update policy at least annually), while ISO/IEC 27001/02 leaves it up to the organization to develop a risk-appropriate approach to determine the frequency. Figure 3 shows the distribution of control gaps in more detail, including the gaps for both the 2013 and 2022 standards.

From these results, we see a significant overall improvement in the evolution from the 2013 version to their 2022 version, as well as in CCM v4 itself. Many of the remaining gaps are due to the specific focus and direction of the standards, as CCM is very prescriptive for its intended audience of CSPs. ISO/IEC 27001/02:2022, on the other hand, is more balanced in its language due to the broader audience, but is still prescriptive in that each organization should define for itself specific policies for given controls.

For the Treacherous Twelve, we also identified the overlap with ISO/IEC 27001/02. The results showed that the 2022 version of the standards had a similar percentage of coverage for each gap type as the overall CCM v4. Specifically, they fully covered 59 controls (approximately 60%) of the controls outlined in the Treacherous Twelve, 39 of the controls (approximately 39%) had partial gaps, and only 1 control (approximately 1%) had no overlap.

4.2 FedRAMP Rev. 5

The latest versions of FedRAMP (i.e., Rev. 4 and Rev. 5) demonstrate comparable coverage for risk, with a significant difference of control domains between them. FedRAMP Rev. 5 encompasses a mapping of new control domains over larger enterprise risk categories. Control additions for Rev. 5 include the expansion of domain controls

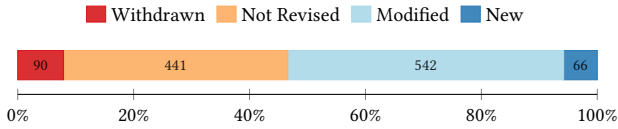


Fig. 4. A breakdown of FedRAMP revision changes and control deltas. The width of each bar indicates the percentage of controls; the value in each bar the number of controls.

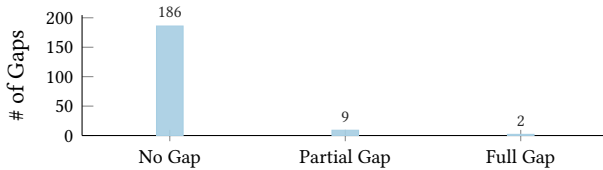


Fig. 5. Gap analysis between FedRAMP Rev. 5 and CCM v4

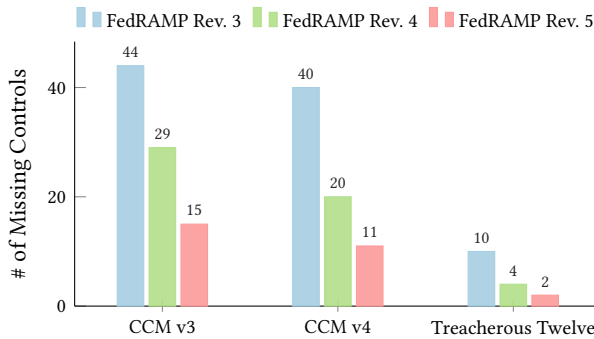


Fig. 6. Comparison of control coverage for missing controls across FedRAMP revisions and CCM risk

around personally identifiable information (PII), software supply chain risk management, and general information management. A total of 66 new base controls were recorded between revisions. The most significant change was the inclusion of new supply chain risk controls, which was substantially enhanced, addressing a large gap in documenting provenance of software, and establishing the need for dedicated Scrum teams as a control for FedRAMP CSPs.

The revisions between FedRAMP Rev. 4 and Rev. 5 resulted in several changes to the controls governing cloud services (see Figure 4). The new revision withdrew risk areas deemed no longer relevant to the overall industry risk profile. In total, 90 controls were withdrawn, which means they are no longer part of FedRAMP Rev. 5; 542 controls were modified, indicating that they have undergone updates or alterations to enhance their effectiveness and address emerging security concerns in cloud environments; and 66 controls are new. The revised controls align more closely with CCM v4 with no control gap between 186 observed controls within CCM v4 and FedRAMP Rev. 5 (see Figure 5).

Figure 6 showcases the progress and improvements in FedRAMP over the past three revisions in aligning with CCM v3 and CCM v4. As the FedRAMP program evolved from Rev. 3 (2012) to Rev. 5

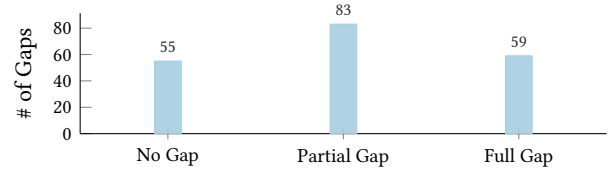


Fig. 7. Gap analysis between SOC 2 and CCM v4

(2023), the number of missing controls against both CCM versions decreased consistently. In 2012, FedRAMP Rev. 3 had 44 missing controls against CCM v3, which was reduced to 29 in Rev. 4 and further to 15 in Rev. 5. The data also shows a similar trend against CCM v4. FedRAMP Rev. 3 had 40 missing controls against CCM v4, which decreased to 20 in Rev. 4 and reached a low of only 11 missing controls in Rev. 5. In addition, Figure 6 highlights FedRAMP’s effectiveness in addressing the “Treacherous Twelve” cloud computing threats. Over the course of three revisions, the program has successfully reduced the number of these threats by 80%.

New Control Coverage. FedRAMP Rev. 5 introduced new control procedures titled A-11 and A-12, which specifically address data loss in the CCM. In addition to these controls, several other changes align the overall framework more closely with the security domains outlined in the CCM. The latest version removes references to “devices” from the control text and makes minor revisions to the discussion section. Notably, there is now a requirement for proof of user identity for logical access based on identity assurance level requirements, reducing the risk of fraudulent identification.

FedRAMP Rev. 5 incorporates the previously withdrawn control IA-4 (3) and necessitates the validation and verification of presented identity evidence through specified methods, performed in-person by a designated registration authority. Furthermore, the previously withdrawn controls IA-4 (7) and IA-5 (3) are also part of Rev. 5. To validate a user’s address, a registration code or notice of proofing must be sent through an out-of-band channel, whether physical or digital. The title of the control set has been changed to “Incident Response Policy and Procedures,” which now requires the selection of organization-level, mission/business process-level, and system-level incident response policies.

4.3 SOC 2

We found that SOC 2 provides full coverage of 28% of the controls contained within CCM v4 with partial gaps identified in 42% of the controls and no overlap for 30% of the controls (see Figure 7). The partial gaps were attributed to the CCM control being partially or mostly related, yet still subsumed within the SOC 2 control. By and large, the SOC 2 control in question was more broad of a concept than the CCM control. In two CCM categories, supply chain management, transparency, and accountability as well as interoperability and portability, we found full and partial gaps, with no control within SOC 2 fully matching the CCM criteria.

We further analyzed the overlap between SOC 2 and the Treacherous Twelve. The findings showed that SOC 2 provides partial coverage across all risks presented in the most recently updated Treacherous Twelve. Although full coverage was not observed for

any risk, partial coverage of SOC 2 controls existed across each risk. The highest coverage of mitigating controls was found against the “Insecure Interfaces and APIs” risk category because SOC 2 contains many of the same identity and access management (IAM) controls.

5 DISCUSSION

In recent years, there has been a marked convergence in risk controls between key frameworks such as ISO/IEC 27001/02, FedRAMP, and SOC 2. This shift aligns with the broader industry trend of accelerated cloud adoption. Many large organizations have moved to a cloud-first strategy [13], and the frameworks that govern technology and risk management have evolved in response.

The evolution of these frameworks over time shows increasing alignment. For example, the most recent versions share more similarities than their predecessors, indicating a consolidation of standards. ISO/IEC 27001/02:2022 has an 88% reduction in missing controls (i.e., “full gaps”) over CCM v4 compared to previous versions, and FedRAMP Rev. 5 has a 75% reduction in missing controls over CCM v4 compared to previous versions.

This trend is further exemplified by the CSA’s CCM version 4. Designed to harmonize elements of ISO/IEC 27001/02, FedRAMP, and SOC 2, CCM v4 encapsulates a holistic approach to risk management. Our comparative analysis shows that the alignment between CCM v4 and the other three frameworks has strengthened. This is evidenced by the decreasing number of “gaps”—areas where one framework may not fully address aspects covered by another, from one version to the next. From our analysis, FedRAMP Rev. 5, provided the highest alignment in coverage to CCM v4, with 94% of controls found in CCM having full coverage. ISO/IEC 27001/02:2022 provided the second highest alignment in coverage to CCM v4, with 61% of controls fully covered and 98% when including controls with partial gaps. SOC 2 had the lowest number of controls with full coverage, with only 28% showing no gaps, but coverage improves to 70% when including controls with partial gaps.

Notable findings also emerged when aligning the frameworks with the most recent version of the “Treacherous Twelve,” which are termed the “Pandemic Eleven” [2]. ISO/IEC 27001/02 and FedRAMP adequately address insufficient identity and credential management, insecure interfaces, misconfiguration, cloud strategy gaps, insecure development, third-party vulnerabilities, system flaws, data disclosure, and data exfiltration. SOC 2, despite gaps compared to the other frameworks, still touches upon each category, which demonstrates its overarching applicability.

5.1 Comparative Analysis of “Full Gaps”

As we look at the specific details of cloud security frameworks, it becomes imperative to understand the differences and gaps between them, especially where we see complete gaps in coverage. By highlighting the differences and unique attributes of each framework, we provide a clearer perspective on areas that may require attention or further alignment, as well as any commonalities.

A comparison of CCM and ISO/IEC 27001/02 reveals several gaps. First, there is a clear requirement in CCM for the explicit definition and implementation of policies that allow data subjects to request access to, or modification or deletion of, their personal data

in accordance with applicable laws—a provision that we do not believe is explicitly addressed in the ISO/IEC standards. Second, the CCM requires periodic testing and necessary updating of incident response plans, especially after significant organizational or environmental changes. Finally, CCM explicitly requires the implementation of automatic lock screens on all endpoints, a specification that is not directly detailed in the ISO standards (the only mention is of remote logout). These discrepancies highlight areas where ISO/IEC 27001/02 could benefit from further refinement to align more closely with the CCM’s specifications.

We identified two primary gaps between CCM and FedRAMP. First, there is an evident need for comprehensive guidance on the applicability of a shared security responsibility model (SSRM) throughout the supply chain. Second, there is an absence of a clear demarcation regarding the shared ownership and applicability of all CSA CCM controls in alignment with SSRM for cloud service offerings. These gaps underscore the importance of a unified understanding and clear delineation of roles in ensuring cloud service security.

As mentioned previously, no control within SOC 2 fully matches the CCM criteria in the control categories for 1) supply chain management, transparency, and accountability and 2) interoperability and portability. There is some overlap here with those observed in our FedRAMP analysis regarding SSRM.

5.2 Limitations

Our work provides an overview of current ISO/IEC 27001/02, FedRAMP, and SOC 2 controls, highlighting overlaps, gaps, and progress over time. Our analysis may not apply to future versions of these standards as they evolve due to errata and future revisions.

6 RELATED WORK

There is extensive literature regarding IT standards for cloud security, but we have not encountered an up-to-date, systematic review of these standards as they relate to current cloud security threats.

Di Giulio et al. [9, 10] conducted the most recent quantitative and systematic review of cloud provider certifications. Their work yields guidance in understanding the overlap and gaps present across ISO/IEC 27001:2013, FedRAMP Rev. 4, and C5 as compared to a baseline set of controls found in the CSA CCM v3. Selecting CSA CCM v3 as the baseline for comparison is primarily due to its completeness and detailed description of a comprehensive set of security controls. In addition, CSA offers a third-party viewpoint, with controls that are not specific to a particular organization, such as the National Institute of Standards and Technology (NIST). The format of a controls checklist also provides a way to obtain measurable results. Di Giulio et al. showed that ISO/IEC 27001:2013 had fewer missing controls as compared to FedRAMP and C5. The missing controls were further compared to the Treacherous Twelve [1] to identify the most significant omissions, such as mobile security.

The CSA CCM is specifically designed to provide fundamental principles to guide cloud vendors and to assist cloud customers in assessing the overall risk of a cloud provider. We selected the CCM as our baseline to facilitate comparison with prior work [9, 10]; CCM v4 also provides a current set of controls for comparison with the latest versions of ISO/IEC 27001/02, FedRAMP, and SOC 2.

A complementary area of research is *mutual auditability* in which CSPs and users must both demonstrate trustworthiness [4]. Ouedraogo et al. [17] propose an event-driven approach to detect anomalies. Ladouceur et al. [15] use network- and hypervisor-based systems to provide visibility into malicious activities by users and co-located virtual machines (VMs). The cloud security frameworks we studied are an alternative to bidirectional transparency [18].

7 CONCLUSION

Cloud computing security is a top priority for industries ranging from the public to the private sector. In order to assure a high degree of security across cloud services, government agencies and organizations, both large and small, are increasingly looking to frameworks to guide their risk selection process. In our analysis, we provided a comparison of three major frameworks: ISO/IEC 27001/02, a global standard; FedRAMP, which is geared towards federal agencies in the United States; and SOC 2, a framework popular with commercial enterprises. Building upon prior work, we compared these frameworks to a common baseline, the CSA's CCM. Through our analysis across version updates, specifically ISO/IEC 27001/02 and FedRAMP, we identified a sharp improvement in their coverage of controls listed in the latest CCM. We also showed through our analysis that ISO/IEC 27001/02 and FedRAMP provide high degrees of coverage across the CCM benchmark. In contrast, SOC 2 provides less coverage but still serves as an alternative to the more stringent FedRAMP and ISO/IEC 27001/02 certifications.

Future Work

The complex landscape of cloud security frameworks continues to evolve with opportunities for further exploration. Future efforts could focus on certifications such as the UK's Cyber Essentials Plus [7] and CSA STAR [5], both of which have the potential to improve cloud security benchmarks. There's also an opportunity to delve deeper into frameworks and standards. Expanding on the differences between the FedRAMP Low, Moderate, and High Baselines and the commonalities within the NIST Cybersecurity Framework (CSF) 1.1 [16] would provide fertile ground for study. Similarly, the emerging ISO/IEC WD 27017, intended as the next iteration of ISO/IEC 27017:2015, promises new insights for cloud services and would be an additional framework for comparison.

In the realm of privacy, the stringent regulations embodied in the European Union's (EU) GDPR are a worthwhile avenue, especially when considered alongside the nuances of cloud security. While we have covered many aspects of ISO/IEC 27018:2019, which addresses regulatory requirements for the protection of PII by CSPs in accordance with ISO/IEC 27002 guidelines, in our analysis, its vast implications for cloud privacy and PII deserve a broader discourse. As researchers navigate this multifaceted terrain, each exploration contributes to the overarching mosaic of understanding in cloud security and privacy.

ACKNOWLEDGMENTS

The views expressed in this paper are those of the authors and do not necessarily reflect the official policy or position of either Johns

Hopkins University or the United States Air Force Academy, the Air Force, the Department of Defense, or the U.S. Government.

REFERENCES

- [1] Cloud Security Alliance. 2016. 'The Treacherous Twelve' Cloud Computing Top Threats in 2016. <https://cloudsecurityalliance.org/artifacts/the-treacherous-twelve-cloud-computing-top-threats-in-2016/>
- [2] Cloud Security Alliance. 2022. Top threats to cloud Computing: Pandemic Eleven. <https://cloudsecurityalliance.org/artifacts/top-threats-to-cloud-computing-pandemic-eleven/>
- [3] Jeff Bardin. 2009. *A Standard, a Framework or a Standard Framework?* <https://www.csoonline.com/article/543353/identity-management-a-standard-a-framework-or-a-standard-framework.html>
- [4] Yanpei Chen, Vern Paxson, and Randy H. Katz. 2010. *What's New About Cloud Computing Security*. Technical Report UCB/EECS-2010-5. Electrical Engineering and Computer Sciences, University of California at Berkeley.
- [5] Cloud Security Alliance. [n.d.]. *Security, Trust, Assurance and Risk (STAR)*. <https://cloudsecurityalliance.org/star/>
- [6] European Commission. 2012. *Unleashing the Potential of Cloud Computing in Europe*. <https://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=COM:2012:0529:FIN:en:PDF>
- [7] The IASME Consortium. 2023. Cyber Essentials Plus. <https://iasme.co.uk/cyber-essentials/cyber-essentials-plus-find-out-more/>
- [8] Chief Information Officers Council. 2019. *From Cloud First to Cloud Smart*. <https://cloud.cio.gov/strategy/>
- [9] Carlo Di Giulio, Read Sprabery, Charles Kamhoua, Kevin Kwiat, Roy H. Campbell, and Masooda N. Bashir. 2017. Cloud Security Certifications: A Comparison to Improve Cloud Service Provider Security. In *Proceedings of the Second International Conference on Internet of Things, Data and Cloud Computing* (Cambridge, United Kingdom) (ICC '17). Association for Computing Machinery, New York, NY, USA, Article 120, 12 pages. <https://doi.org/10.1145/3018896.3025169>
- [10] Carlo Di Giulio, Read Sprabery, Charles Kamhoua, Kevin Kwiat, Roy H. Campbell, and Masooda N. Bashir. 2017. Cloud Standards in Comparison: Are New Security Frameworks Improving Cloud Security?. In *2017 IEEE 10th International Conference on Cloud Computing (CLOUD 2017)*. IEEE, 50–57. <https://doi.org/10.1109/CLOUD.2017.16>
- [11] Center for Internet Security. 2020. *CIS Controls v8 Mappings to AICPA Trust Services Criteria (SOC 2)*. <https://www.cisecurity.org/insights/white-papers/cis-controls-v8-mapping-to-aicpa-trust-services-criteria-soc2>
- [12] Blair Franklin. 2023. The digital forecast: 40-plus cloud computing stats and trends to know in 2023. Google Cloud Blog. <https://cloud.google.com/blog/transform/top-cloud-computing-trends-facts-statistics-2023>
- [13] Stan Gibson. 2022. *Cloud-first strategy forces big shift on IT infrastructure, skills*. <https://www.techtarget.com/searchcio/feature/Cloud-first-strategy-forces-big-shift-on-IT-infrastructure-skills>
- [14] Luke Irwin. 2023. *ISO 27001 vs SOC 2 Certification: What's the Difference?* <https://www.itgovernance.eu/blog/en/iso-27001-vs-soc-2-certification-whats-the-difference>
- [15] Daniel Ladouceur, Bimmy Pujari, Edward Gleeck, and Joel Coffman. 2019. Techniques for Mutual Auditability in a Cloud Environment. In *Proceedings of the 12th IEEE/ACM International Conference on Utility and Cloud Computing Companion* (Auckland, New Zealand) (UCC '19 Companion). Association for Computing Machinery, New York, NY, USA, 117–122. <https://doi.org/10.1145/3368235.3368875>
- [16] NIST. 2018. *Framework for Improving Critical Infrastructure Cybersecurity*. NIST. <https://doi.org/10.6028/NIST.CSWP.04162018>
- [17] Moussa Ouedraogo, Eric Dubois, Djamel Khadraoui, Sebastien Poggi, and Benoit Chenal. 2015. Adopting an Agent and Event Driven Approach for Enabling Mutual Auditability and Security Transparency in Cloud based Services. In *Proceedings of the 5th International Conference on Cloud Computing and Services Science - CLOSER*. INSTICC, SciTePress, 565–572. <https://doi.org/10.5220/0005496205650572>
- [18] Moussa Ouedraogo, Severine Mignon, Herve Cholez, Steven Furnell, and Eric Dubois. 2015. Security transparency: the next frontier for security research in the cloud. *Journal of Cloud Computing* 4, 1 (June 2015), 12. <https://doi.org/10.1186/s13677-015-0037-5>